

#23 · 簽名連結

[優化] 技術代號 S-P0-2 / S-P0-3 · 約 2-3 天

一句話：媒體連結直接暴露

為什麼要修

所有人拿到 R2 / GCS 連結都能直接看。

現在怎樣

server/storage.ts 內 s3Upload / gcsUpload 只回公開 URL，未實作 signed URL。S3 versioning 未開、無 lifecycle policy。

問題在哪

使用者「私人草稿」可能被連結外流。誤覆寫無法救回。

要改什麼

新增 getSignedAssetUrl() 中介層、對外永遠經此拿短期簽名連結（15 min）。手動開啟 S3 versioning + 對 tmp/ failed/ 設 7 天 TTL。

涉及檔案

server/services/internalMedia.ts（新增 getSignedAssetUrl）

server/storage.ts（s3SignUrl / gcsSignUrl helper）

server/routers.ts（既有對外 asset 端點全部改用 getSignedAssetUrl）

scripts/setup-bucket-lifecycle.sh（新增 idempotent 套用工具）

Claude Code 提示詞 (複製貼上)

把下面這段話完整複製，貼到 Claude Code (或 /claude 對話)。Claude Code 會依此完成此項修復。完成後跑下方驗證步驟確認。

請依照計畫附錄 A.12 與 A.13 實作 S-P0-2 簽名 URL 中介 + S-P0-3 bucket 設定：

【第 1 部分：signed URL】

1. 在 server/services/internalMedia.ts 新增：

```
```typescript
export async function getSignedAssetUrl(relKey: string, expiresInSec = 900): Promise<string> {
 const provider = detectStorageProvider();
 if (provider === "s3") return s3SignUrl(relKey, expiresInSec);
 if (provider === "gcs") return gcsSignUrl(relKey, expiresInSec);
 return getPublicUrl(relKey); // local fallback
}
```
```

2. 在 server/storage.ts 實作 s3SignUrl 與 gcsSignUrl：

- S3：用 @aws-sdk/s3-request-presigner 的 getSignedUrl
- GCS：用 @google-cloud/storage 的 file.getSignedUrl({ version: 'v4', action: 'read', expires: now+expiresInSec*1000 })

3. 修改所有對外 API 端點 (asset list、history detail、generation result 等)，把直接吐 bucket URL 的地方換成 getSignedAssetUrl(assetId, 900)。對敏感資源 (私人草稿、未公開 LoRA) 改為 300 (5 min)。

4. 確認前端載入流程：圖片 / 影片 / 音檔每次都呼叫 API 拿新 signed URL，不要 cache 過長時間 (避免 URL 過期前圖片仍掛著但已不可用)。

【第 2 部分：S3 versioning + lifecycle】

5. 新增 scripts/setup-bucket-lifecycle.sh (idempotent，CI 可重跑)：

```
```bash
#!/bin/bash
Open versioning
aws s3api put-bucket-versioning --bucket $BUCKET --versioning-configuration Status=Enabled

Lifecycle policy
cat <<EOF > /tmp/bucket-lifecycle.json
{
 "Rules": [
```

```
{ "ID": "expire-tmp", "Filter": { "Prefix": "tmp/" }, "Status": "Enabled", "Expiration": { "Days": 7 } },
{ "ID": "expire-failed", "Filter": { "Prefix": "failed/" }, "Status": "Enabled", "Expiration": { "Days": 7 } },
{ "ID": "old-versions", "Status": "Enabled", "NoncurrentVersionExpiration": { "NoncurrentDays": 90 } }
]
}
```

EOF

```
aws s3api put-bucket-lifecycle-configuration --bucket $BUCKET --lifecycle-configuration
```

```
file:///tmp/bucket-lifecycle.json
```

```

```

6. 修改 internalMedia.ts:classifyByKey 確保失敗 / 暫存任務分別寫到 failed/ 與 tmp/ prefix。

不要做的事：不要做 CDN 整合（屬第 33 條未來擴張）。不要對「公開資產」（公開 showcase）做 signed URL（會破壞分享功能）。不要把 signed URL 過期時間設太短（< 5 min 會破壞使用者瀏覽體驗）。

## 如何驗證做完了

在前端開啟一張私人圖 → 開 DevTools Network 看 src URL 含 X-Amz-Signature 或 X-Goog-Signature → 15 分鐘後再用同 URL → 403 Forbidden。Bucket console 看到 versioning enabled、tmp/ 7 天 expiration rule。

## 預估耗時

2-3 天